Project SUTRA System Architecture

As of 2 November 2026

0. Project in and out

SUTRA is a vendor quotation management system for an automotive parts buyer. It is complete through the award step and passed 71 of 71 acceptance checks on 1 Nov 2026. Vendors send quotations as PDF, Excel or Word files; SUTRA reads them, checks the arithmetic, compares vendors side by side, and an authorised manager records the award with a full audit trail.

The problem it solves

- Quotations arrive in many formats and layouts, so someone retypes every line.
- Vendors' own totals can be wrong.
- Missing terms (warranty, validity, payment, delivery) are easy to miss.
- An award needs a reason and a record of who decided.

Principles

- **AI assists, people decide.** The system never approves or selects a vendor.
- **Backend arithmetic.** Every total is recalculated in BigDecimal; AI figures are only compared against it.
- **Nothing is lost.** Original files are kept in the database, even when reading fails.
- **Every action is recorded.** The audit log cannot be edited or deleted.
- **Rules live on the server.** The UI only hides what a role cannot use.

How the project got here

Date	Stage	What changed
2 Nov 2026	Folder layout	Project reorganised into frontend/, backend/ (was services/), database/, ai/ and docs/; login no longer waits for the 3D scene
2 Nov 2026	New frontend	Light red and white redesign: GSAP preloader, three.js hex-nut scene, Framer Motion, dark grouped sidebar, global search, dashboard with alerts and risk notifications
1 Nov 2026	Acceptance	71 of 71 checks passed in 227 s against the full stack (`docs/ACCEPTANCE_RESULTS.md`)
1 Nov 2026	New test pack	Automotive RFQ for 5 production materials; 3 vendors, each sending a PDF quotation plus an Excel material list (`ai/test-data/`)
1 Nov 2026	Version 2 gaps closed	Vendor self-service portal, Vendor role, read-only Auditor replaces Viewer, menus per role, tests on a separate `sutra_test` database, OpenAI engine removed
1 Nov 2026	Version 2 microservices	Monolith split into gateway, auth, master data, procurement and audit services on a shared `sutra-common` library; audit events through outboxes
1 Nov 2026	Version 1 monolith	One Spring Boot backend, 7 migrations, IT-

Date	Stage	What changed
		hardware test pack; spec check 58 of 63 rules done, 5 partial (`docs/SPEC_COMPLIANCE_V1.md`)

Acceptance result on the test pack

Rank	Vendor	System grand total (INR)	Grade	Outcome
1	Vertex Auto Materials	36,22,788.80	A (92)	Awarded, warranty to be fixed in the PO
2	Shakti Metals & Components	37,02,250.00	A (94)	Not awarded
3	Pioneer Industrial Supplies	37,23,962.00	A (92)	Not awarded

All three system totals matched the expected totals exactly. The rule-based reader reached the same totals without AI, and Vertex's open bearing warranty was flagged as missing information.

The 71 checks cover: master-data CRUD and relationships (10), users and vendor logins (5), RFQ publishing and file storage (11), invalid files and failed extraction (7), review and item matching (12), backend totals and no automatic award (9), access control, audit trail, lockout and service health (17).

Technology

Layer	Stack
Frontend	React 18.3, Vite 6.4, React Router 6.30, Axios 1.21, GSAP 3.15, Framer Motion 14.9, three.js 0.170 with React Three Fiber 8.18
Services	Java 17, Spring Boot 4.1.2, Spring Security 7.1, Hibernate 7.4, Flyway 12.4, jjwt 0.12.6, springdoc 3.2
Document service	Python 3.12, FastAPI, rapidfuzz
Database	PostgreSQL 18
AI	Google Gemini free models over REST, no SDK
Tests	JUnit 6, Mockito 5.23, pytest, Vitest 3.2 with Testing Library

Run it

1. One time: `psql -U postgres -h localhost -f database/scripts/01_create_database.sql`
2. One time: create the Python venv in `ai/` and run `npm install` in `frontend/`.
3. Start everything: `.\start-all.ps1` (builds the services and opens one window per service).
4. Open http://localhost:5173 and sign in as `admin` / `Admin@123`, then change the password.
5. Stop everything: `.\stop-all.ps1`
6. Acceptance run: `.\start-all.ps1 -Acceptance`, then `ai\.venv\Scripts\python ai\scripts\acceptance_test.py`

Configuration

Variable	Default	Purpose
GEMINI_API_KEY	unset	Enables Gemini; without it the rule-based reader is used
GEMINI_MODEL	gemini-3.8-flash	Model used for extraction
GEMINI_FALLBACK_MODELS	gemini-3.5-flash-lite	Tried when the main model is rate-limited
SUTRA_ENGINE_ORDER	GEMINI,RULES	Engines that Automatic tries, in order
SUTRA_EXTRACTION_CONCURRENCY	1	Extractions running at once

Variable	Default	Purpose
DB_URL / DB_USERNAME / DB_PASSWORD	sutra_db / sutra / sutra_pass	Database connection
JWT_SECRET	development value	Must be set (32+ characters) in any shared setup
SUTRA_ADMIN_PASSWORD	Admin@123	First administrator's password, empty database only
SUTRA_MAX_FILE_BYTES	20 MB	Upload limit
CORS_ORIGINS	http://localhost:5173	Allowed browser origins

Repository layout

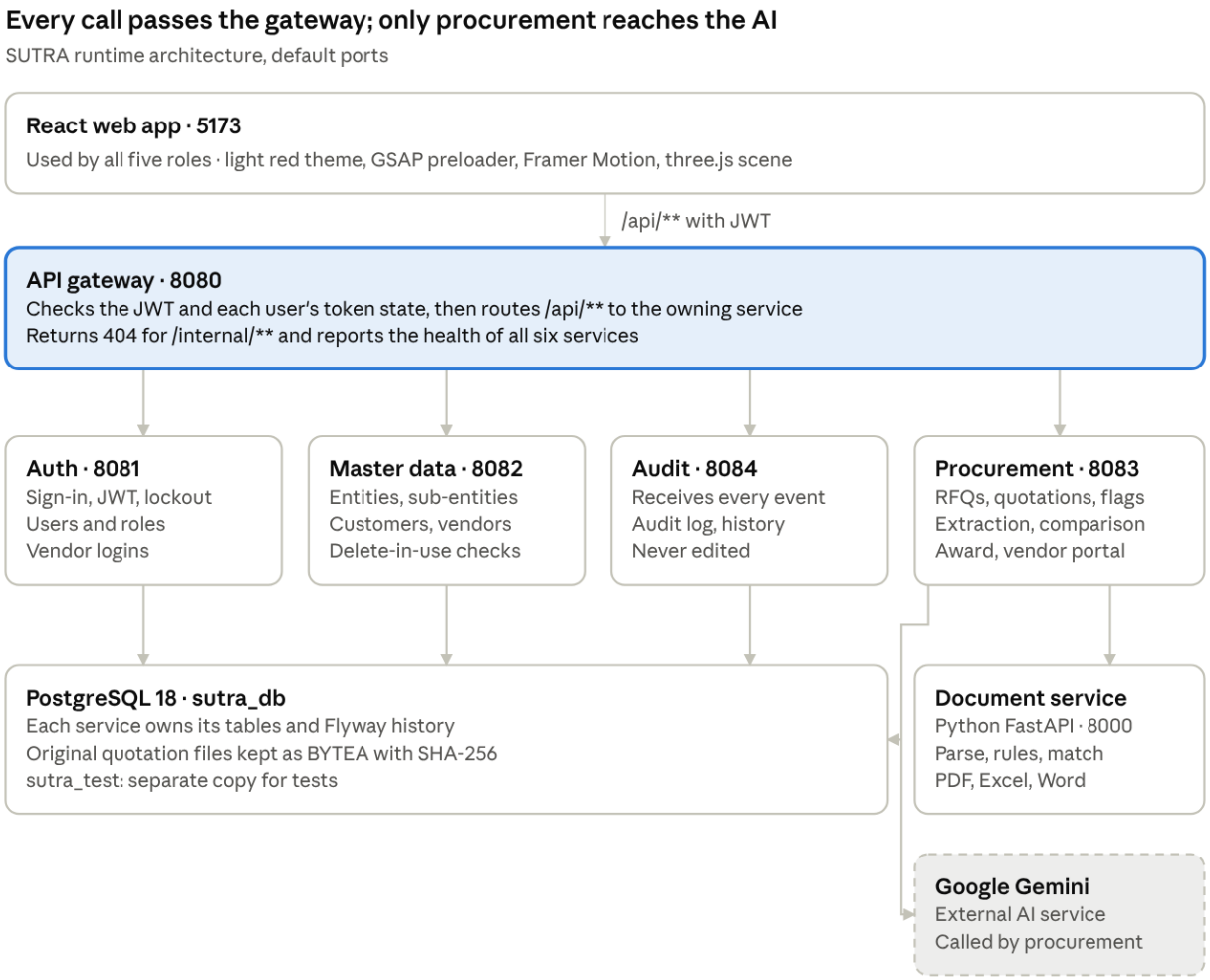
Folder	Contents
frontend/	React web app
backend/	gateway, auth-service, masterdata-service, procurement-service, audit-service, sutra-common, parent pom.xml
backend/archive/	Version 1 monolith backend
database/	Schema per service (auth, masterdata, procurement, audit), create and reset scripts
database/archive/	Version 1 migrations
ai/	Python document service: app, tests, generated samples
ai/test-data/	Automotive test pack (RFQ, 3 vendors' quotations, materials catalogue) and the v1 IT-hardware test pack
ai/scripts/	Acceptance test, data pack generator
docs/	This document (.docx and .pdf), acceptance results, version 1 specification check
start-all.ps1, stop-all.ps1	Start or stop every service

Not done yet

- Scanned PDFs need Gemini; there is no local OCR.
- SUTRA stops at the award: no purchase orders, contracts or invoices.
- The sign-in lockout is held in memory, so a restart clears it.
- No email notifications to vendors.
- No demo-data loader for `sutra_db`; `README.md` still describes the removed OpenAI engine.

1. System map

Every browser call goes to the gateway on port 8080, which checks the token and forwards it to the service that owns the path. Only procurement talks to the document service and Gemini.



SUTRA architecture

Services call each other over `/internal/**` routes that the gateway hides from outside. Each service writes its audit events to its own outbox in the same transaction as the change, and a relay delivers them to the audit service, so no event is lost.

Part	Port	Responsibility
React web app	5173	All screens for all five roles; Vite proxies /api to the gateway
API gateway	8080	Token check, token-state cache, routing, hides /internal/**, service health
Auth service	8081	Sign-in, JWT, lockout, change password, users, roles, vendor logins
Master data service	8082	Entities, sub-entities, customers, vendors, delete-in-use checks
Procurement service	8083	RFQs, quotations, extraction, flags, review, comparison, award, vendor portal, dashboard
Audit service	8084	Receives audit events; serves the audit log and record history

Part	Port	Responsibility
Document service	8000	Python FastAPI: parse PDF/Excel/Word, rule-based reading, fuzzy matching
PostgreSQL 18	5432	sutra_db (application) and sutra_test (tests)
Google Gemini	external	AI extraction, called only by procurement

2. Roles and features

Five roles, each with its own feature tree. Every action lists its API call and the rule that guards it; the services check each rule again, so hiding a button is never the only protection.

Role	Code	In one line
Administrator	ADMIN	Sets up the company, suppliers and logins; can also do everything a buyer and manager can
Buyer	PROCUREMENT	Creates RFQs, uploads and reviews quotations, generates comparisons, on own RFQs only
Manager	APPROVER	Reads everything and awards or rejects RFQs, never ones they raised
Auditor	AUDITOR	Read-only: RFQs, comparisons, awards and the full audit log
Vendor	VENDOR	A supplier's own login: sees open RFQs and only its own quotations

2.1 Administrator (ADMIN)

Created automatically on an empty database as `admin` / `Admin@123`.

- **Account** (user menu, top right)
  - **Change password** (`POST /api/auth/change-password`)
    - Enter current password, new password, confirmation
    - At least 8 characters, one letter and one digit
    - Wrong current password refused: `INVALID_CURRENT_PASSWORD`
    - New password must differ: `PASSWORD_UNCHANGED`
    - Raises the user's token version, so sessions on other devices end
  - Sign out (clears the token in the browser)
- **Entities**, the buying company (`/entities`)
  - **Create entity** (`POST /api/entities`)
    - Code (unique), name, description, address, active
    - Duplicate code refused: 409
  - List and search (`GET /api/entities`)
  - Edit entity (`PUT /api/entities/{id}`)
  - **Delete entity** (`DELETE /api/entities/{id}`)
    - Blocked while it has sub-entities: 422 `ENTITY_HAS_SUB_ENTITIES`
    - Blocked while an RFQ or customer uses it (master data asks procurement through `/internal/usage`)
  - **Sub-entities** (plants, departments)
    - Create under an entity (`POST /api/entities/{id}/sub-entities`): code, name, description, active
    - Code unique within its entity: 409
    - List (`GET /api/entities/{id}/sub-entities`)
    - Edit (`PUT /api/entities/{id}/sub-entities/{subId}`)
    - Delete (`DELETE /api/entities/{id}/sub-entities/{subId}`)
- **Customers** (`/customers`)
  - Create, edit, delete (`/api/customers`): code, name, contact person, email, phone, address, active
  - Must belong to an existing entity: 404 `ENTITY_NOT_FOUND`

    - Can be linked to an RFQ
- **Vendors**, the suppliers (`/vendors`)
    - Create (`POST /api/vendors`): code, name, contact person, email, phone, address, tax number, website, active
    - Search by name or code (`GET /api/vendors?q=`)
    - Edit (`PUT /api/vendors/{id}`)
    - Delete (`DELETE /api/vendors/{id}`), then 404 `VENDOR_NOT_FOUND`; blocked while quotations use it
- **Users and roles** (`/users`)
    - **Create company user** (`POST /api/users`)
        - Username 3 to 60 letters, digits, dot, dash or underscore; can never change: `USERNAME_IMMUTABLE`
        - Username and email unique: 409
        - Full name and initial password: `PASSWORD_REQUIRED`
        - One or more roles: Administrator, Buyer, Manager, Auditor
    - **Create vendor login**
        - Role VENDOR, linked to exactly one vendor: `VENDOR_REQUIRED`
        - A vendor login cannot hold a company role: `VENDOR_ROLE_EXCLUSIVE`
        - Only a VENDOR user can be linked to a vendor: `VENDOR_ROLE_REQUIRED`
    - List roles (`GET /api/users/roles`)
    - Edit details, roles, reset password, activate or deactivate (`PUT /api/users/{id}`)
        - Deactivating ends that user's open session at once: 401 `SESSION_EXPIRED`
        - Cannot deactivate yourself or remove your own ADMIN role: `SELF_LOCKOUT`
    - Delete user (`DELETE /api/users/{id}`): not yourself (`SELF_DELETE`), not a user with history (`USER_IN_USE`)
- **RFQs, quotations, comparison, award**
    - Everything in the Buyer tree, on any RFQ
    - Everything in the Manager tree, including RFQs they raised
- **Oversight**
    - Award register (`/awards`)
    - Full audit log (`GET /api/audit-logs`)
    - Getting-started checklist on the dashboard, ticked off from real counts

2.2 Buyer (PROCUREMENT)

A buyer may change only the RFQs they raised (RecordAccessPolicy); other buyers' RFQs are read-only (403).

- **RFQs** (`/purchase-requests`)
    - Search by title or number, filter by status, paginate (`GET /api/purchase-requests`)
    - **Create RFQ** (`POST /api/purchase-requests`)
        - Title, description, entity, sub-entity, customer, currency, required-by date
        - Number generated, e.g. `PR-2026-00001`; starts as Draft
    - **Requested items**
        - Add item code, description, quantity, unit, specifications (`POST .../items`)
        - Edit or remove (`PUT` or `DELETE .../items/{itemId}`)
    - Edit or delete the RFQ (`PUT` or `DELETE /api/purchase-requests/{id}`)
    - Open it to vendors or cancel it (`PATCH .../{id}/status`)
- **Quotations** (RFQ page, Quotations tab)
    - **Upload for a vendor** (`POST /api/purchase-requests/{id}/quotations`)

        - One or several files form one quotation (PDF, Excel, Word)
        - Pick the engine: Automatic, Gemini or rule-based; optional Gemini model
        - Type, size, real content and Office structure checked: 415 or 400 with a clear message
        - Progress bar; returns at once while reading runs in the background
    - **Review a quotation** (`/quotations/{id}`)
        - Extracted header and lines, matched request item, confidence, quality grade A to F
        - Edit header: number, dates, validity, currency, terms (`PUT /api/quotations/{id}`)
        - Add, correct or remove lines; edited lines are marked (`.../items`)
        - Resolve or accept each flag with a comment (`.../flags/{flagId}/resolve`)
        - Re-read with another engine (`POST .../reprocess`)
        - Cross-check: read with every engine side by side, nothing saved (`POST .../cross-check`)
        - Mark ready for comparison (`POST .../mark-ready`)
        - Add or remove files; download originals byte for byte (`.../files`)
        - Change history of the quotation (`GET .../history`)
        - Enter the quotation by hand when reading failed; the backend computes the totals
    - Delete a quotation (`DELETE /api/quotations/{id}`)
- **Comparison** (RFQ page, Comparison tab)
    - Generate a new version (`POST .../{id}/comparisons`)
    - Side-by-side matrix: unit prices, line totals, lowest per line, price spread, missing items
    - Grand totals, rank, advisory vendor grade, missing information, unmatched lines
    - Export to CSV
    - The RFQ moves to Comparing and stops accepting vendor uploads (422)
    - Disclaimer: the system never selects or approves a vendor
- **Vendors**: look up suppliers when uploading for them (`/vendors`, read-only)
- **Cannot**: award (403), read the full audit log (403), change master data or users (403)

2.3 Manager (APPROVER)

- **Award decision** (`POST /api/purchase-requests/{id}/approvals`)
    - Award one quotation, or reject the RFQ
    - A reason is required when it is not the lowest complete quotation: 422 `REASON_REQUIRED`
    - Records who, when and why in the approval table
    - The RFQ closes as Awarded or Rejected; vendors see Awarded or Not awarded
    - Decision history (`GET .../approvals`)
- **Read**: all RFQs, quotations, comparisons and files; award register; audit log; RFQ history timeline
- **Cannot**: upload or edit quotations (403); award an RFQ they raised (403)

2.4 Auditor (AUDITOR)

- **Compliance**: audit log filtered by record type, record id and user, paginated (`GET /api/audit-logs`); entries cannot be edited or deleted
- **Reports**: award register; any RFQ, its comparison and history, read-only
- **Cannot**: upload (403); award (403)

2.5 Vendor (VENDOR)

Lands on the supplier portal and never sees company screens or other vendors.

- **Open RFQs** (`/portal`)
  - Cards of RFQs open for quotations (`GET /api/vendor-portal/rfqs`)
  - RFQ detail: buyer, items, quantities, specifications, required-by date (`GET .../rfqs/{id}`)
  - **Send quotation** (`POST .../rfqs/{id}/quotations`)
    - PDF, Excel or Word; several files form one quotation
    - One quotation per vendor per RFQ: 409
    - Closed once the RFQ is being compared: 422
- **My quotations** (`/portal/quotations`)
  - Status of each quotation and its outcome: Awarded or Not awarded
  - Download own files (`GET .../quotations/{id}/files/{fileId}`)
  - Withdraw while the RFQ is still open (`DELETE .../quotations/{id}`)
- **Cannot**: use any company API (403), list other vendors (403), download another vendor's file (404)

2.6 Every user

- **Sign in** (`POST /api/auth/login`)
  - Returns a JWT and the user; current user via `GET /api/auth/me`
  - 5 failed attempts lock the username for 15 minutes: 429 `ACCOUNT_LOCKED`
  - Failed and blocked attempts are audited
  - Company users land on the dashboard, vendors on the portal; an expired session returns to sign-in
- **Change password** from the user menu, same rules as above
- **Dashboard** for company users (`GET /api/dashboard`)
  - Cards: total vendors, active RFQs, pending, awarded contracts
  - Alerts: quotation validity expiring within 14 days, outstanding decisions
  - Risk notifications: failed extractions, expired offers, overdue RFQs, flagged quotations, services down
  - Vendor quotation status ring chart, RFQ pipeline bars, quick actions, recent activity, system health
- **Global search** (Ctrl+K): pages, RFQs and vendors the role may read

3. Workflow

An RFQ goes through eight steps from setup to audit, and a person makes every decision. The RFQ page shows the steps as a tracker.

7. **Set up**: the administrator adds the entity, sub-entities, vendors and logins.
8. **Create the RFQ**: the buyer lists the items needed and opens it to vendors.
9. **Collect**: vendors upload in the portal, or the buyer uploads for them.
10. **Read and check**: an engine extracts the lines; the backend recalculates and raises flags.
11. **Review**: the buyer corrects data, resolves flags and marks quotations ready.
12. **Compare**: side-by-side matrix, ranking and advisory grades.
13. **Award**: the manager awards or rejects, with a reason when needed.
14. **Audit**: every step is in the audit trail and the award register.

RFQ status (purchase_request.status)

Status	Shown as	Set when
DRAFT	Draft	The RFQ is created
OPEN	Open	The buyer opens it; vendors can see it and send quotations
UNDER_REVIEW	Comparing	A comparison is generated; vendor uploads close
APPROVED	Awarded	A manager awards a quotation
REJECTED	Rejected	A manager rejects the RFQ
CANCELLED	Cancelled	The buyer cancels it

Quotation status (quotation.status)

Status	Set when
UPLOADED	Files are stored
PROCESSING	An engine is reading the files
NEEDS_REVIEW	Reading finished with at least one open flag
READY_FOR_COMPARISON	No open flags, or the buyer marks it ready
FAILED	Every engine failed or found no lines; files and each engine's reason are kept, so the buyer can retry or enter it by hand

Both status lists are also enforced by CHECK constraints in the database.

4. Extraction pipeline

An uploaded file goes through eight stages inside the procurement service, in the background, one extraction at a time by default so free AI tiers stay within their limits. AI reads the document; the backend does all the arithmetic.

15. **Validate** (QuotationFileValidator): extension, size up to 20 MB, magic bytes, Office package structure; a clear message for old `.doc` files.
16. **Store**: original bytes in `quotation_file` with name, format, size, SHA-256 and upload time.
17. **Choose the engine**: Automatic tries Gemini, then the rule-based reader, and moves on when an engine is not configured, is rate-limited, fails or finds no lines. A rate-limited Gemini model first falls back to `gemini-3.5-flash-lite`.
18. **Read**: Gemini gets PDFs directly (scanned ones too) and Excel or Word as text from the document service's `/parse`. The rule-based reader runs in the document service's `/extract`.
19. **Merge files**: all files of one quotation are read together; each line appears once, and figures that differ between files are flagged.
20. **Match** (HybridItemMatcher): exact item code first (e.g. `MT-101`), then description and specification similarity via `/match`, with a local Java fallback.
21. **Calculate** (QuotationCalculator): every line, discount, tax, subtotal and grand total recomputed in BigDecimal, rounding HALF_UP, and compared with the printed figures.
22. **Flag and grade**: QuotationValidator and TermsCheck raise flags; ExtractionQualityGrader gives a grade from A to F out of 100.

The 26 automatic flags

Each flag has a severity (INFO, WARNING or ERROR), and a reviewer resolves it with a comment.

Area	Flag codes
Reading	LOW_CONFIDENCE, EXTRACTOR_NOTE, NO_ITEMS_EXTRACTED, VENDOR_NAME_MISMATCH
Line values	MISSING_QUANTITY, MISSING_UNIT_PRICE, LINE_TOTAL_MISMATCH, DISCOUNT_CONFLICT, TAX_CONFLICT
Totals	SUBTOTAL_MISMATCH, TAX_TOTAL_MISMATCH, GRAND_TOTAL_MISMATCH, DOCUMENT_LEVEL_TAX
Matching	UNMATCHED_ITEM, LOW_MATCH_CONFIDENCE, MISSING_REQUEST_ITEM, QUANTITY_MISMATCH, UOM_MISMATCH
Currency and validity	MISSING_CURRENCY, CURRENCY_MISMATCH, MISSING_VALIDITY, VALIDITY_EXPIRED
Terms	MISSING_PAYMENT_TERMS, MISSING_DELIVERY_TERMS, INCOMPLETE_TERMS, CONDITIONAL_TERMS

Advisory vendor grade (VendorGrader)

Shown beside the comparison out of 100 points; it never decides the award.

Criterion	Points
Price	40
Coverage of requested items	15
Delivery terms	10
Payment terms	10
Warranty	10
Validity	10
Open flags	5

Cross-check re-reads a quotation with every available engine and shows the readings side by side, graded the same way, without saving anything. The reviewer can then re-run the extraction with the engine they trust.

5. Services and APIs

Six services sit behind the gateway, and each owns its own tables. In the Who column: **Staff** = Administrator, Buyer, Manager and Auditor; **Edit** = Administrator or Buyer (a buyer only on their own RFQs); **Readers** = Administrator, Manager and Auditor; **Services** = internal calls between services only.

5.1 Gateway (port 8080)

ProxyController, GatewayFilter, TokenStateCache, ServiceStatusController. Owns no tables.

Method	Path	Does	Who
any	/api/**	Forwards to the owning service	Signed in
GET	/api/system/services	Health and response time of all six services	Staff
any	/internal/**	Always 404 from outside	Nobody

5.2 Auth service (port 8081)

AuthService, UserService, LoginAttemptService, JwtCodec. Owns `role`, `app_user`, `user_role`, `audit_outbox`.

Method	Path	Does	Who
POST	/api/auth/login	Sign in, returns JWT	Anyone
GET	/api/auth/me	Current user	Signed in
POST	/api/auth/change-password	Change own password	Signed in
GET	/api/users	List users	Admin
GET	/api/users/roles	List roles	Admin
GET	/api/users/{id}	One user	Admin
POST	/api/users	Create user or vendor login	Admin
PUT	/api/users/{id}	Edit, roles, activate, reset password	Admin
DELETE	/api/users/{id}	Delete user	Admin
GET	/internal/users/{id}/token-state	Active flag and token version	Gateway
GET	/internal/vendors/{vendorId}/logins	Logins of a vendor	Services

5.3 Master data service (port 8082)

BusinessEntityService, CustomerService, VendorService. Owns `business_entity`, `sub_entity`, `customer`, `vendor`, `audit_outbox`.

Method	Path	Does	Who
GET	/api/entities	List, search	Staff
GET	/api/entities/{id}	One entity	Staff
POST	/api/entities	Create entity	Admin
PUT	/api/entities/{id}	Edit entity	Admin
DELETE	/api/entities/{id}	Delete if unused	Admin
GET	/api/entities/{id}/sub-entities	List sub-entities	Staff
POST	/api/entities/{id}/sub-entities	Create sub-entity	Admin
PUT	/api/entities/{id}/sub-entities/{subId}	Edit sub-entity	Admin
DELETE	/api/entities/{id}/sub-entities/{subId}	Delete sub-entity	Admin
GET	/api/customers, /api/customers/{id}	List, one customer	Staff
POST, PUT, DELETE	/api/customers[/{id}]	Create, edit, delete	Admin
GET	/api/vendors, /api/vendors/{id}	List, search, one vendor	Staff
POST, PUT, DELETE	/api/vendors[/{id}]	Create, edit, delete	Admin
GET	/internal/entities/{id},	Lookups for procurement	Services

Method	Path	Does	Who
	/internal/entities/{entityId}/sub-entities/{subId}		
GET	/internal/customers/{id}, /internal/vendors/{id}	Lookups for procurement	Services
GET	/internal/stats	Counts for the dashboard	Services

5.4 Procurement service (port 8083)

PurchaseRequestService, QuotationService, QuotationProcessingService, QuotationReviewService, ExtractionCrossCheckService, ComparisonService, ApprovalService, VendorPortalService, DashboardService; calculation package with QuotationCalculator, QuotationValidator, TermsCheck, ComparisonEngine, VendorGrader, ExtractionQualityGrader. Owns `purchase_request`, `request_item`, `quotation`, `quotation_file`, `quotation_item`, `quotation_flag`, `comparison_report`, `comparison_quotation`, `approval`, `audit_outbox`.

RFQs (`/api/purchase-requests`)

Method	Path	Does	Who
GET	/	Search by q and status, paginated	Staff
GET	/{id}	One RFQ with items	Staff
POST	/	Create	Edit
PUT	/{id}	Edit	Edit
DELETE	/{id}	Delete	Edit
PATCH	/{id}/status	Open, cancel	Edit
POST	/{id}/items	Add item	Edit
PUT	/{id}/items/{itemId}	Edit item	Edit
DELETE	/{id}/items/{itemId}	Remove item	Edit
GET	/{id}/quotations	Quotations of the RFQ	Staff
POST	/{id}/quotations	Upload files with vendorId, engine, geminiModel	Edit
GET	/{id}/comparisons	Comparison versions	Staff
POST	/{id}/comparisons	Generate a comparison	Edit
GET	/{id}/approvals	Decisions	Staff
POST	/{id}/approvals	Award or reject	Admin, Manager

Quotations (`/api/quotations/{id}`)

Method	Path	Does	Who
GET	/	Quotation with lines, flags, grade	Staff
PUT	/	Edit header	Edit
DELETE	/	Delete	Edit
GET	/files/{fileId}	Download original	Staff
POST	/files	Add files	Edit
DELETE	/files/{fileId}	Remove file	Edit
POST	/reprocess	Re-read with an engine	Edit
POST	/cross-check	Read with every engine, not saved	Edit
POST	/mark-ready	Ready for comparison	Edit
POST	/items	Add line	Edit
PUT	/items/{itemId}	Correct line	Edit
DELETE	/items/{itemId}	Remove line	Edit
POST	/flags/{flagId}/resolve	Resolve flag with comment	Edit

Vendor portal, reporting and internal

Method	Path	Does	Who

Method	Path	Does	Who
GET	/api/vendor-portal/rfqs, /api/vendor-portal/rfqs/{id}	Open RFQs, one RFQ	Vendor
POST	/api/vendor-portal/rfqs/{id}/quotations	Submit quotation	Vendor
GET	/api/vendor-portal/quotations	Own quotations and outcomes	Vendor
DELETE	/api/vendor-portal/quotations/{id}	Withdraw	Vendor
GET	/api/vendor-portal/quotations/{id}/files/{fileId}	Own file	Vendor
GET	/api/dashboard	Counts and engine in use	Staff
GET	/api/comparisons/{reportId}	One comparison	Staff
GET	/api/extraction-engines	Engines, models, availability	Staff
GET	/internal/usage/{kind}/{id}	Is an entity or vendor in use?	Services

5.5 Audit service (port 8084)

AuditLogService. Owns `audit_log` and its own `audit_outbox`.

Method	Path	Does	Who
GET	/api/audit-logs	Filter by record type, id, user	Readers
GET	/api/purchase-requests/{id}/history	RFQ timeline	Staff
GET	/api/quotations/{id}/history	Quotation timeline	Staff
POST	/internal/audit-events	Receive events from other services	Services

5.6 Document service (port 8000)

Python 3.12 FastAPI: `parsers.py`, `rules.py`, `matcher.py`, `schemas.py`. Called only by procurement; owns no tables.

Method	Path	Does
GET	/health	Liveness
POST	/parse	PDF, Excel or Word to text and tables
POST	/extract	Rule-based quotation reading
POST	/match	Fuzzy matching of quoted lines to requested items

6. Data model

One PostgreSQL 18 database, `sutra_db`, holds 17 tables plus 4 outbox tables; each service owns its tables and its own Flyway history. Money is NUMERIC, never floating point. A link to a table owned by another service is stored as an id (often with a copy of the name) and checked through an internal API. `sutra_test` is a separate database for tests and acceptance runs.

Service	Table	Columns	Links and rules
auth	role	id, name, description	Seeded: ADMIN, PROCUREMENT, APPROVER, AUDITOR, VENDOR
auth	app_user	id, username, email, full_name, password_hash, active, vendor_id, vendor_name, token_version, created_at, updated_at	Username and email unique; username pattern CHECK; vendor_id and vendor_name both set or both empty
auth	user_role	user_id, role_id	→ app_user, → role
masterdata	business_entity	id, code, name, description, address, active, created_at, updated_at	Code unique
masterdata	sub_entity	id, entity_id, code, name, description, active, created_at, updated_at	→ business_entity (RESTRICT); code unique within its entity
masterdata	customer	id, code, name, entity_id, contact_person, email, phone, address, active, created_at, updated_at	Code unique; → business_entity (RESTRICT)
masterdata	vendor	id, code, name, contact_person, email, phone, address, tax_number, website, active, created_at, updated_at	Code unique
procurement	purchase_request	id, request_number, title, description, entity_id, entity_name, sub_entity_id, sub_entity_name, customer_id, customer_name, requested_by_id, requested_by_name, status, currency, required_by, created_at, updated_at	Status CHECK
procurement	request_item	id, purchase_request_id, line_number, item_code, description, quantity, unit_of_measure, specifications	→ purchase_request
procurement	quotation	id, purchase_request_id, vendor_id, vendor_name, quotation_number, quotation_date, valid_until, currency, status, subtotal, discount_total, tax_total, grand_total, stated_subtotal, stated_tax_total, stated_grand_total, delivery_terms, payment_terms, warranty_terms, notes, extraction_source, extraction_confidence, failure_reason, processing_attempts,	→ purchase_request; status CHECK; valid_until not before quotation_date

Service	Table	Columns	Links and rules
		last_processed_at, uploaded_by_id, uploaded_by_name, submitted_by_vendor, version, created_at, updated_at	
procurement	quotation_file	id, quotation_id, file_name, content_type, file_format, size_bytes, sha256, content, uploaded_by_id, uploaded_by_name, uploaded_at	→ quotation; content is BYTEA
procurement	quotation_item	id, quotation_id, request_item_id, line_number, item_code, description, quantity, unit_of_measure, unit_price, discount_percent, discount_amount, tax_percent, tax_amount, line_total, stated_line_total, match_confidence, extraction_confidence, manually_edited, notes	→ quotation, → request_item
procurement	quotation_flag	id, quotation_id, quotation_item_id, field_name, severity, code, message, resolved, resolved_by_id, resolved_by_name, resolved_at, created_at	→ quotation, → quotation_item
procurement	comparison_report	id, purchase_request_id, report_version, generated_by_id, generated_by_name, generated_at, lowest_complete_quotation_id, details	→ purchase_request; details is JSON
procurement	comparison_quotation	comparison_report_id, quotation_id, quotation_version, grand_total, items_quoted, items_missing, price_rank	→ comparison_report, → quotation
procurement	approval	id, purchase_request_id, comparison_report_id, selected_quotation_id, decision, reason, decided_by_id, decided_by_name, decided_at	Decision CHECK (APPROVED or REJECTED)
audit	audit_log	id, event_id, service, entity_type, entity_id, purchase_request_id, action, performed_by, performed_at, received_at, details	details is JSON; never edited or deleted
each service	audit_outbox	One per service that writes audit events	Event written in the same transaction as the change

The main chain: business_entity → sub_entity; purchase_request → request_item; purchase_request → quotation → quotation_file, quotation_item, quotation_flag; purchase_request → comparison_report → comparison_quotation; purchase_request → approval.

7. Security, audit and shared rules

The shared `sutra-common` library gives every service the same token check, role names, audit outbox and error format.

Authentication

- JWT signed with `JWT_SECRET` (JwtCodec); every service checks the token again (JwtAuthenticationFilter), not only the gateway.
- Passwords hashed with BCrypt.
- `token_version` on each user: changing the password or deactivating the user makes old tokens fail. The gateway caches each user's token state (TokenStateCache) from the auth service.
- 5 failed sign-ins lock the username for 15 minutes (HTTP 429); failures older than the window are forgotten.

Authorisation in three layers

23. **Endpoint**: `@PreAuthorize` on every route, using the shared role groups STAFF, ADMIN, VENDOR and AUDIT_READERS.
24. **Record**: RecordAccessPolicy lets buyers change only their own RFQs; the vendor portal returns only the signed-in vendor's own quotations and files.
25. **Business rule**: ApprovalService blocks awarding an RFQ you raised and requires a reason when the choice is not the lowest complete quotation.

The UI (`permissions.js`) mirrors these rules only to decide what to show.

Audit trail

- AuditService writes each event into the service's own `audit_outbox` in the same database transaction as the change, so an event is never lost.
- AuditOutboxRelay delivers events to the audit service (`POST /internal/audit-events`) and retries until it succeeds.
- Recorded: sign-ins and failed sign-ins, every create, edit and delete, uploads, extractions, flag resolutions, comparisons and decisions.
- Extraction is recorded as the system, uploads as the vendor who sent them, awards as the manager.

Errors

- GlobalExceptionHandler returns one error shape (ApiError) with status, code, message and request id.
- Exception types: ResourceNotFound (404), DuplicateResource (409), BusinessRule (422), ForbiddenOperation (403), ServiceUnavailable (503), AccountLocked (429).
- Named exceptions from the specification: EntityNotFound, VendorNotFound, QuotationNotFound, UnsupportedQuotationFile, QuotationProcessing.
- RequestIdFilter tags every request so one call can be traced across services.

Data safety

- Logs hold ids, names and sizes only, never file contents, passwords or secrets.
- Gemini requests are sent with `store: false`.
- CHECK constraints guard statuses, validity dates and approvals; deletes are blocked while a record is in use.
- CORS is limited to `CORS_ORIGINS`.

Testing

Part	Tools	What is covered
Java services	JUnit 6, Mockito	Service rules with mocked repositories and AI; PostgreSQL integration tests on `sutra_test`; Gemini tested against a mock HTTP server
Document service	pytest	38 tests: parsers, rule-based reader on both test packs, matcher, API
Frontend	Vitest, Testing Library	46 tests: sign-in, role menus, portal, comparison, approval, grading, dashboard
Whole system	`ai/scripts/acceptance_test.py`	71 end-to-end checks on the test pack, all passed

8. Frontend

One React app serves all five roles; each route is wrapped in RequireAuth with the roles allowed to open it, and every page reads live data from the APIs (no sample data).

Routes

Route	Page	Shows	Roles
/login	LoginPage	3D hex-nut scene and sign-in card	Anyone
/	DashboardPage	Cards, alerts, risk notifications, charts, quick actions, activity, system health	Staff
/purchase-requests	PurchaseRequestsPage	RFQ list, search, status filter, New RFQ	Admin, Buyer, Manager
/purchase-requests/:id	PurchaseRequestDetailPage	Step tracker, items, quotations, upload, comparison, award, history	Staff
/quotations/:id	QuotationReviewPage	Lines, flags, files, grade, cross-check, reprocess, manual entry	Staff
/awards	AwardRegisterPage	Awarded and rejected RFQs	Admin, Manager, Auditor
/entities	EntitiesPage	Entities and their sub-entities	Admin
/customers	CustomersPage	Customer CRUD	Admin
/vendors	VendorsPage	Vendor CRUD (admin) or lookup (buyer)	Admin, Buyer
/users	UsersPage	Users, roles, vendor logins	Admin
/audit	AuditLogPage	Filtered audit trail	Admin, Manager, Auditor
/portal	VendorRfqsPage	Open RFQs	Vendor
/portal/rfqs/:id	VendorRfqDetailPage	RFQ detail and quotation upload	Vendor
/portal/quotations	VendorQuotationsPage	Own quotations and outcomes	Vendor

Shell and look

- **Theme**: light red and white throughout, with a dark wine sidebar.
- **Sidebar**: icons, grouped as Overview, Contracts (RFQs), Vendors, Compliance (Audit log), Reports (Award register) and Administration; the highlight slides between items.
- **Top bar**: global search (Ctrl+K) across pages, RFQs and vendors, plus a user menu with Change password and Sign out.
- **Preloader** (GSAP): light-red threads draw in from the edges and weave into the SUTRA hex-nut logo, the letters rise in with a 0 to 100% counter, then the screen parts like a curtain. Once per browser session; skipped when reduced motion is on.
- **3D scene** (three.js with React Three Fiber): a glossy hex nut with orbiting vendor beads that follows the mouse. Its code downloads while the preloader plays, and it mounts only after the preloader ends and the browser is idle, so the login form works immediately; a flat drawing shows when WebGL is missing.
- **Motion** (Framer Motion): page transitions, staggered cards, animated charts; numbers count up with GSAP.

Building blocks

- **Shared components**: ComparisonMatrix, ApprovalPanel, CrossCheckPanel, EnginePicker, FilePicker, Grade, HistoryTimeline, CrudPage, PurchaseRequestForm, QuotationItemForm, ChangePasswordModal, Modal, Toast, Tabs, StatusBadge, Icon, GlobalSearch, Preloader, Scene3D.

- **Data**: Axios client adds the JWT and handles expired sessions; the `useApi` hook loads data and ignores stale replies; `endpoints.js` lists every API call.
- **Helpers**: `permissions.js` (what each role sees), `format.js` (money in INR, dates, labels), `comparisonCsv.js` (CSV export).
- **Development**: Vite on port 5173 proxies `/api` to the gateway on 8080; `npm run build` produces `dist/`, with three.js split into its own chunk.